

⚙️ Security Orchestration

SentinelLine

Explainable Malware Triage on Top of Assemblyline

Policy-Driven

Auditable

Explainable

FastAPI • FSM • Assemblyline • YARA • JSONL Audit Dashboard

The Problem

Malware triage needs speed, consistency, and evidence-backed routing.

Noisy & Expensive

Manual analysis is slow and resource-intensive. Analysts need a way to separate low-risk files from suspicious samples quickly.

Hard to Explain

Routing decisions need clear rationale and traceability. A black-box result is difficult to defend during review.

Inconsistent Policy

Without a structured workflow, different analysts may apply different criteria to similar samples.

Goal: automate triage without hiding the reasoning — fast, auditable, policy-consistent.

What SentinelLine Does

The runtime path is a seven-state finite-state workflow, not a single monolithic function.

01

Receive

Accept uploaded file via REST API

02

Triage

Entropy, file type, and YARA pre-analysis

03

Route

Choose FAST, DEEP, or
HUMAN_REVIEW

04

Submit

Send file + policy settings to
Assemblyline

05

Wait

Poll for completion and fetch results

06

Score

Normalize signals and compute
confidence

07

Respond

Return recommendation + dashboard
payload

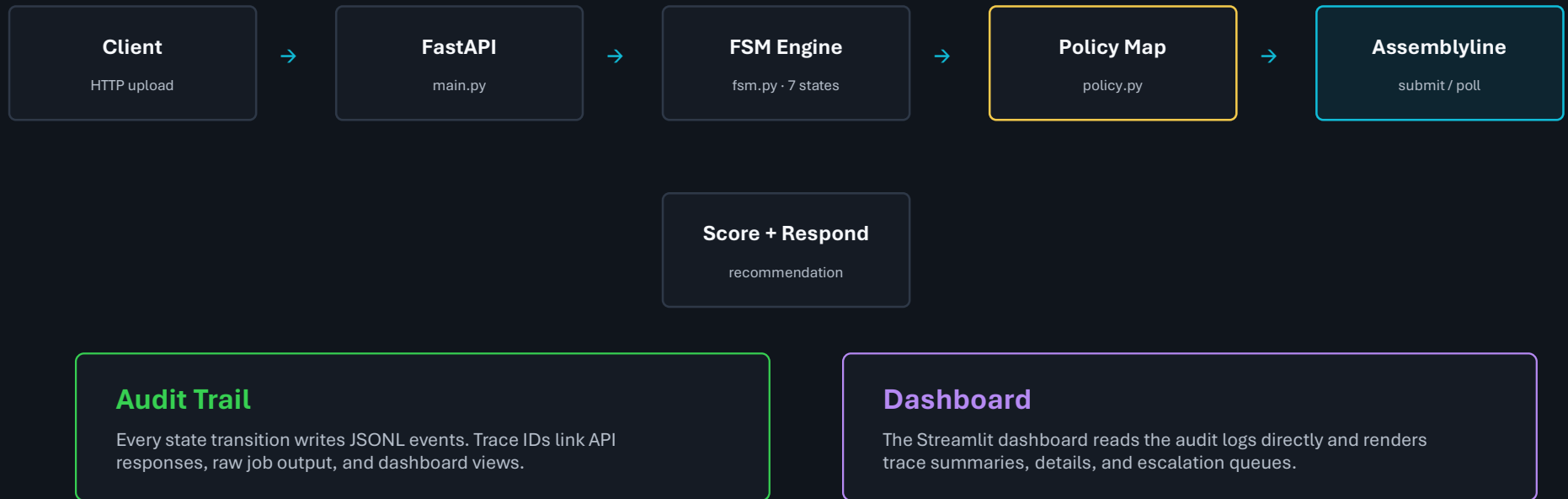
```
POST /submit
↓
run_fsm(filename, content)
↓
state handlers write JSONL audit events
↓
final JSON response
```

Output

Recommendation · final score · confidence · routing rationale · dashboard
payload · per-trace audit log

System Architecture

SentinelLine orchestrates the workflow; Assemblyline performs the malware analysis.



Design point: the dashboard does not read directly from Assemblyline; it visualizes SentinelLine's audit trail.

Pre-Analysis Triage

Signals are computed before submission and used to build an initial risk profile.

Entropy Analysis

High entropy can indicate packing, compression, or encryption. It is treated as one suspicious signal, not proof of malware.

File Type Detection

Magic bytes and MIME detection help identify executables or disguised files regardless of extension naming.

YARA Rule Matching

Pattern signatures detect known or suspicious code sequences before the file is sent to Assemblyline.

Output: entropy · file_type · yara_hits · initial_risk_score · metadata_summary → feeds deterministic routing

Routing Logic

The route state makes a deterministic decision using the triage profile.

FAST

Low-risk or clean triage profile

Minimal / quick analysis path

DEEP

Suspicious indicators without definitive signature

Expanded policy with longer timeout and selected services

HUMAN_REVIEW

Definitive signature or high-risk escalation criteria

Marks sample for analyst review and writes escalation events

Inputs considered: `yara_hit_count` · `definitive signature flag` · `initial risk score` · `entropy` · `file type`

Policy Mapping

Routes map to explicit submission policies in agent/app/policy.py.

Route	Policy ID	Timeout	Deep Scan	Extra Services	Analysis Type	Selected Services
FAST	STATIC_OFFLINE	60s	No	None	quick	Default / minimal
DEEP	DYNAMIC_OFFLINE	600s	Yes	yara, pe_recommendations	standard	Antivirus, Extraction, Static Analysis
HUMAN_REVIEW	ESCALATED	1800s	Yes	yara, pe_recommendations, code_analysis	comprehensive	Antivirus, Extraction, Static Analysis

Policy fields: `policy_id` · `timeout` · `deep_scan` · `extra_services` · `selected_services` · `analysis_type`

Assemblyline Submission

SentinelLine delegates malware analysis to Assemblyline through a REST API.

1 Authenticate

Credentials are loaded from environment variables — not hardcoded.

2 Build Payload

File plus policy settings: timeout, deep_scan, services, metadata.

3 POST to Assemblyline

Submit to `/api/v4/submit/` and receive a submission ID.

4 Poll + Fetch

Wait for completion, then retrieve the analysis payload for scoring.

```
Policy-derived payload fields:  
timeout · deep_scan · extra_services · analysis_type  
services.selected · metadata.sentinelline_route  
metadata.sentinelline_policy_id · metadata.sentinelline_policy_name
```

Scoring & Recommendation

Scoring is computed from available report signals; recommendation logic is applied in `respond.py`.

Score Stage

Parses report metrics, computes confidence, normalizes final risk score, and uses triage fallback when analysis signals are unavailable.

Respond Stage

Builds the final report, sets final status, determines recommendation, and applies escalation logic.

Important Correction

The current implementation is not a simple 0–25 / 26–50 / 51–75 / 76–100 threshold slide. Use actual trace examples.

Example Trace

Backdoor.Win32.Poison.cn00_4a33.exe → YARA: Triage_Persistence → Route: DEEP / DYNAMIC_OFFLINE → Score: 40 → QUARANTINE

Audit Trail & Dashboard

JSONL audit logs connect runtime events, dashboard views, and test artifacts.

SentinelLine Audit Dashboard

Trace Overview

trace_id	filename	route	policy_id	score	recommendation	status
79092eaf-1fa8-4ff7-8b75-34dfb72431f9	Backdoor.Win32.Poison.cnoo_4a33.exe	DEEP	DYNAMIC_OFFLINE	2f	RECEIVED	RECEIVED
577e9bd4-09be-4f72-91a1-bc687f409e75	sha256_ch1.txt	FAST	STATIC_OFFLINE	6j	RECEIVED	RECEIVED
92958c96-e0c1-497f-af59-a69f5b8fd82d	ircbot_strings.txt	DEEP	DYNAMIC_OFFLINE	6l	RECEIVED	RECEIVED
39aeb0eb0-ea2e-40ae-b406-61d057d5eae3	complete_detector.py	FAST	STATIC_OFFLINE	Q	RECEIVED	RECEIVED
5fa1fdc3-b8a3-406e-b6ff-e6f3dd835607	fakedpdfmalware.exe	HUMAN	ESCALATED	3r	RECEIVED	RECEIVED
101e5fb3-65a2-41f3-aed7-a4cf90fe7666	fakeword.exe	DEEP	DYNAMIC_OFFLINE	1s	RECEIVED	RECEIVED
2b1bb72e-30e2-4463-928a-8db4f7151268	ircbot.exe	DEEP	DYNAMIC_OFFLINE	Pk	RECEIVED	RECEIVED
79360788-fec5-42af-accd-88d223cc2bba	benign.txt	FAST	STATIC_OFFLINE	7l	RECEIVED	RECEIVED
6642e276-2ce1-4b31-8560-12c99b21e82a	Backdoor.Win32.Poison.cnoo_4a33.exe	DEEP	DYNAMIC_OFFLINE	1j	RECEIVED	RECEIVED
a4761457-ffed-49a2-b2bb-0e3a6f47eab2	sha256_ch1.txt	FAST	STATIC OFFLINE	VI	RECEIVED	RECEIVED

Trace Overview: route, policy, score, recommendation, status

Needs Analyst Review

trace_id	filename	route	policy
5fa1fdc3-b8a3-406e-b6ff-e6f3dd835607	fakedpdfmalware.exe	HUMAN_REVIEW	ESCA
6c772848-0dfa-4003-a533-c1dd1593b23b	fakedpdfmalware.exe	HUMAN_REVIEW	ESCA
bf482c33-faf2-489f-a94e-093b16d45322	fakedpdfmalware.exe	HUMAN_REVIEW	ESCA
b768a2dd-408b-4343-be1c-6319aec59143	27cace85f340ddf29e4167e9aaf3df25b46c75e5	HUMAN_REVIEW	ESCA
d93ec228-c63d-4df5-bced-254458af0211	395f5806ae10b5ef67ac28b09adf1d38e914a9e9	HUMAN_REVIEW	ESCA
59cf91bc-6073-489c-84ef-8c216f808d27	6a3f3ac4bb3bd9fb6b370ac5a6e71eba02cfd14	HUMAN_REVIEW	ESCA
baea3cd4-fcab-48e1-8b68-760911966c9c	a3a674385f3c23a1f3d80c6b5fb557bee3c747ff	HUMAN_REVIEW	ESCA
41bbd868-d362-42fd-8d9f-eb1d045d2fea	a580dc57fbf83386877a43ec2cdee13a579f3c6	HUMAN_REVIEW	ESCA
63ef5a93-1378-434e-a46b-af4e8e46711d	8358a01fad0deccd25598cf08e3b6e050d782ba7	HUMAN_REVIEW	ESCA
9e51d9b2-bb95-4d15-add9-2f56583db02c	e8439520acd39c54ab1486af23d1ef7285de56e9	HUMAN_REVIEW	ESCA

Needs Analyst Review: HUMAN_REVIEW / ESCALATED cases

Trace Details expands each run into RECEIVED → TRIAGE → ROUTE → SUBMIT → WAIT → SCORE → RESPOND events.

Testing & Validation

Validation combines controlled samples, trace inspection, and concurrent submission runs.

Benign Sample

Expected: FAST route

Typical result: IGNORE / complete

Suspicious Sample

Expected: DEEP route

Example result: QUARANTINE / complete

Definitive Sample

Expected: HUMAN_REVIEW route

Result: pending_human_review + escalation log

Stress Test

Concurrent submissions

Records pass/fail, p50/p95 latency, route distribution, errors

Note: the stress harness demonstrates concurrent execution behavior and reporting; it does not by itself prove the absence of all race conditions.

Limitations & Future Work

The current boundaries are clear and are good roadmap opportunities.

Current Limitations

- No complete analyst approve/dismiss workflow yet
- SentinelLine does not launch or switch Assemblyline infrastructure profiles
- External threat-intel enrichment is mostly stubbed
- Scoring depends on stable report shape / fallback paths

Future Improvements

- Analyst approval workflow with persistent decisions
- External threat-intel enrichment such as VirusTotal or MISP
- Service health checks before submission
- More calibration for risk scoring
- Richer dashboard filtering and trace search

SentinelLine

Policy-Driven

Auditable

Explainable

An orchestration layer that decides how to analyze a file, explains the reasoning, submits to Assemblyline, and surfaces results in a traceable dashboard.